

Foot Printing tools - Competitive Intelligence

Foot Printing is the process of collecting information about a target organization. In passive foot printing, information is gathered from publicly available sources without directly interacting with the target company's servers.

Following tools can be used:

- 1) WHOIS: used to obtain domain registration details such as register name, registration/expiration dates, name servers and publicly available registration information. It helps understand the company's domain infrastructure.
- 2) The Harvester: An OSINT tool used to find publicly indexed employee mail addresses, hotnames and related information. It can also reveal the organization email naming pattern.
- 3) Wappalizer: These tools identify the technologies used by a public website, such as CMS, frameworks, JavaScript libraries, analytics services, hosting and CDN technologies.
- 4) Crt.sh: Searches Certificate Transparency logs and can reveal publicly exposed subdomains such as mail.ex.com.

Competitive intelligence: These tools help understand an organization's public digital presence, technologies, employees and infrastructure. The collected information can also be used to compare the organization.

2) DNS Zone Transfer

A DNS Zone transfer is used to copy DNS records from one DNS server to the another. A full zone transfer uses the AXFR mechanism. During an authorized penetration test, the analyst can check whether a DNS server is incorrectly allowing unauthorized zone transfers.

First test to zone transfer against an authorized target:

`dig ns example.com`

Then test the zone transfer against an authorized target

`dig AXFR example.com`

`dns.example.com`

if the DNS is properly configured, the request should normally be refused. If the transfer succeeds

Important records:

A record: Identify hostnames and their IP addresses

Mx records: Identify organizational mail servers.

Records: identify authoritative name servers
NAME Records: reveal aliases and related services
TXT Records: may reveal SPF, verification and other
Public Configuration information.

for example The retrieved records might reveal
DNS-visible host such as mail.exm.com

Countermeasure: Zone transfer should be restricted
so that authorized secondary DNS servers can
perform AXFR/IXFR requests.

3) Social Engineering attack and Countermeasures.

The given scenario is a phishing attack,
which is a common type of social engineering attack
the attacker pretends to be the organization's IT
department and creates their credentials through a
provided link.

Employees should follow these countermeasures.

* Do not immediately click the link. Instead, access
the organization's website or posted through a known
trusted method.

- 1) Verify the sender: Check the complete sender email address and domain rather than trusting only the displayed name.
- 2) Check Suspicious Links: Confirm the sender mail should verify where a link leads before opening it and avoid unknown or mismatched domains.
- 3) Contact the IT department: Confirm the request using an official phone number help desk system or trusted communication channel.
- 4) Never share Passwords or OTPs: Employees should never provide passwords, OTPs or recovery codes in response to unsolicited emails.
- 5) Use multi-factor authentication's MFA: Provides an additional authentication layer. Reducing the impact of stolen passwords.
- 6) Report Phishing: Suspicious messages should be reported to the organization security or IT team so that they can investigate and warn other employees.

Security awareness training: Regular training helps employees identify suspicious emails, fake login pages, Impersonation and urgency-based manipulation.